Guia de Sobrevivência Nível 1 (Teórica Guiada)

Projeto Final DevSecOps Clube Aurora (Turma 1746)

> [SEGURANÇA] **Bem-vindo(a) ao Nível 1!**
> Se você não é desenvolvedor(a), não domina terminal ou atua nas áreas de **Governança, Riscos, Compliance (GRC), LGPD, Gestão ou Auditoria**, esta trilha foi desenhada sob medida para você.
> **Aqui você não precisa programar em Python, instalar Docker ou rodar comandos complexos no Git.** O seu papel é atuar como **Consultor(a) Estratégico(a) de Segurança e DevSecOps**, analisando relatórios técnicos reais, traduzindo vulnerabilidades para impactos financeiros/reputacionais e redigindo pareceres executivos para a diretoria.

---

1. Como Funciona a Sua Avaliação

No Nível 1, você tem uma missão muito clara e acolhedora:

1. **Você recebe evidências pré-geradas:** A equipe técnica já rodou os scanners de segurança (Trivy, Semgrep, Hadolint) e salvou os relatórios prontos para você na pasta `aluno/evidencias_pipeline/`.
2. **Você analisa 4 casos didáticos:** F1 (Segredos expostos), F2 (Bibliotecas desatualizadas), F3 (Injeção de SQL) e F4 (Contêiner como Root).
3. **Você emite um parecer de governança:** Avalia o pedido do Tio Armando para dar acesso de "Admin Geral" à gerente Carla.
4. **Você redige um memorando executivo de 3 parágrafos:** Explica para o CEO por que a segurança viabiliza as vendas em vez de travá-las.
5. **Você escolhe o formato de entrega mais confortável:**
   - **No Word (.docx):** Se preferir, baixe o arquivo `TEMPLATE_TG.docx`, preencha no Microsoft Word ou Google Docs e envie o documento final conforme as orientações da **professora**.
   - **No Markdown (.md):** Se preferir, preencha o `TEMPLATE_TG.md` diretamente no editor de texto.

---

2. O Mapa da Mina: Onde Encontrar as Informações

Para preencher seu relatório, você só precisa de 3 fontes de consulta:

```
1. HISTÓRIA DO CASO          2. EVIDÊNCIAS PRONTAS          3. GLOSSÁRIO DIDÁTICO
   (ENUNCIADO.md)               (evidencias_pipeline/)            (GLOSSARIO.md)
Conheça o Tio Armando, a    Veja os logs reais dos         Entenda termos como CIA,
Carla, o Léo e os riscos.   scanners sem complicação       STRIDE, SCA, SAST, RBAC.
```

- **História do Caso:** Leia as seções 1 e 2 do `ENUNCIADO.md`. Elas explicam o modelo de negócio do concierge de luxo e a notícia fictícia do vazamento.
- **Relatórios dos Scanners:** Na pasta `aluno/evidencias_pipeline/`, você encontrará excertos reais dos scanners com as tabelas de vulnerabilidades.
- **Dicionário de Segurança:** Se encontrar alguma sigla desconhecida, consulte o `GLOSSARIO.md`.

3. Roteiro Passo a Passo de Preenchimento do Relatório

Abra o seu template de entrega (`TEMPLATE_TG.docx` ou `TEMPLATE_TG.md`) e acompanhe as orientações abaixo:

PARTE 1: Análise de Ameaças & Impacto de Negócio

Caso 1 (F1): Segredos de Produção Expostos no Repositório

- **A Metáfora da Vida Real:** É o equivalente a construir uma mansão blindada, mas deixar a chave da porta principal e o código do alarme anotados em um bilhete colado na campainha.
- **O que fazer:** Este caso já está **100% resolvido no seu template**! Ele serve exatamente como a sua régua de estilo, profundidade e vocabulário para responder aos próximos casos.

Caso 2 (F2): Dependências Desatualizadas com Falhas Conhecidas (SCA)

- **A Metáfora da Vida Real:** É o equivalente a uma companhia de aviação utilizar peças de reposição em suas aeronaves que já sofreram *recall* oficial do fabricante por risco de quebra em pleno voo.
- **Onde olhar:** Abra o arquivo `evidencias_pipeline/evidencia_trivy_fs.md`. Observe a tabela de pacotes (`gunicorn` , `werkzeug` , `urllib3`) e a coluna `Title` com a descrição dos riscos.
- **Perguntas Orientadoras para o seu texto:**
  1. *Qual categoria STRIDE se aplica?* Se uma falha no Gunicorn permite *HTTP Request Smuggling* (misturar requisições de clientes diferentes) ou no Werkzeug causa travamento do servidor, pense: isso afeta a disponibilidade (**Denial of Service**) ou a privacidade (**Information Disclosure**)?
  2. *Qual pilar da Tríade CIA é mais ferido?* Se o sistema travar durante um leilão de arte VIP em que clientes disputam um lote em tempo real, qual pilar caiu? (**Disponibilidade**). Se cookies de sessão vazarem, qual pilar caiu? (**Confidencialidade**).
  3. *Impacto no Negócio:* Descreva em 2 ou 3 frases o prejuízo para a reputação do Clube Aurora se o sistema sair do ar no meio de uma reserva de jato executivo.
  4. *Ação Corretiva:* Qual é a ação necessária? (Dica: a equipe de tecnologia deve atualizar as versões das bibliotecas no manifesto de dependências e colocar um scanner automático na esteira).

Caso 3 (F3): Injeção de SQL (SQL Injection) na Busca de Clientes (SAST)

- **A Metáfora da Vida Real:** É como um formulário de recepção de hotel onde, em vez de assinar seu nome, o visitante escreve uma ordem judicial falsa dizendo *"Mostre-me a lista de todos os hóspedes da suíte presidencial e suas senhas de cofre"*, e a recepcionista obedece sem conferir.
- **Onde olhar:** Leia o trecho de código citado no template (`app/db.py` linha 102) e o relatório do Semgrep em `evidencias_pipeline/evidencia_semgrep.md` .
- **Perguntas Orientadoras para o seu texto:**
  1. *Qual é o erro básico?* O código está pegando o que o usuário digita na barra de pesquisa e "colando" diretamente na ordem SQL do banco de dados (concatenação de texto / f-string), sem filtrar caracteres especiais como aspas.
  2. *STRIDE & CIA:* O invasor consegue extrair dados privados (**Information Disclosure** / **Confidencialidade**) e potencialmente adulterar informações (**Tampering** / **Integridade**).
  3. *Impacto no Negócio do Clube Aurora:* Imagine que criminosos obtenham o endereço residencial, a agenda de viagens internacionais e as preferências pessoais de milionários e celebridades. Conecte

isso às multas da LGPD (que podem chegar a 2% do faturamento ou R$ 50 milhões por infração grave) e processos indenizatórios.
4. *Solução:* Explicar com suas palavras o conceito de **parâmetros preparados (prepared statements / placeholders com `?`)**: o banco de dados deve tratar o texto digitado estritamente como texto de busca, e nunca como uma ordem executável.

Caso 4 (F4): Contêiner Executando como ROOT e Imagem sem Hardening

- **A Metáfora da Vida Real:** É como dar ao operador de xerox ou ao funcionário temporário o chaveiro mestre do edifício que abre todas as salas da diretoria e o cofre central.
- **Onde olhar:** Veja a seção do `Dockerfile` no template e a explicação dos "4 Mandamentos do Hardening de Contêineres" no `ENUNCIADO.md`.
- **Perguntas Orientadoras para o seu texto:**
  1. *Marque os mandamentos violados:* No `Dockerfile` original, a aplicação roda como `root`? Usa imagem `:latest` pesada? Não usa multi-stage? Marque com um **X** todas as caixas que se aplicam.
  2. *Impacto no Negócio:* Se uma falha na aplicação for explorada enquanto ela opera com poder de superusuário (`root`), o invasor não fica preso apenas àquela aplicação: ele pode escapar do contêiner (*container escape*), assumir o controle do servidor da nuvem e instalar ransomware ou apagar backups de toda a empresa.

PARTE 2: Governança, Menor Privilégio & O Pedido da Carla (F6)

O Tio Armando pediu para você dar acesso de **Administrador Geral** tanto para ele quanto para a nova gerente de atendimento, Carla, para que ela "resolva qualquer problema dos clientes na hora".

1. Você concorda em dar Admin Geral para a Carla?

Marque com clareza: **Não**.

2. Como justificar tecnicamente com base no Princípio do Menor Privilégio (PoLP) e SoD?

Utilize este roteiro de raciocínio para construir sua resposta (1 a 2 parágrafos):
- **O que a Carla precisa no dia a dia?** Ela precisa consultar itinerários, aprovar reservas de jatos, atualizar preferências gastronômicas e emitir recibos de concierge.
- **O que o perfil de Administrador Geral permite?** Permite apagar o banco de dados, criar ou demitir outros usuários, alterar parâmetros de segurança do servidor e apagar logs de auditoria.
- **O Risco da Conta Única/Excessiva:** Se a senha da Carla vazar em um ataque de phishing ou se ela cometer um erro acidental ao mexer no painel, o dano pode ser irreversível.
- **Segregação de Funções (SoD):** Funções de suporte e atendimento não devem ter poder sobre a governança técnica e segurança do sistema.
- **A Solução Elegante:** Proponha a criação de um perfil customizado (**Gerente de Concierge / `concierge_manager`**), que dá à Carla 100% das ferramentas necessárias para encantar o cliente VIP sem expor a infraestrutura central do Clube Aurora.

PARTE 3: O Memorando Executivo para o Tio Armando

Aqui você demonstrará sua habilidade de comunicação corporativa. O Tio Armando é um empresário focado em vendas e crescimento rápido; portanto, mensagens cheias de jargões técnicos excessivos serão ignoradas. Ele precisa entender que **segurança protege o patrimônio dele**.

Escreva um memorando profissional e amigável dividido rigorosamente em **3 parágrafos curtos**:

- **Parágrafo 1 O Reconhecimento e a Metáfora de Valor:**
- Comece parabenizando pelo sucesso estrondoso do Clube Aurora.
- Use uma analogia elegante: atender o público de altíssimo padrão (UHNWI) exige discrição absoluta. Assim como uma joalheria de luxo não expõe diamantes em vitrines de vidro simples na calçada, o sistema digital do clube precisa de blindagem correspondente. A segurança é a garantia da exclusividade dos membros.
- **Parágrafo 2 O Risco Real Traduzido para Finanças e Lei:**
- Explique sem rodeios o que aconteceria caso as falhas atuais vazassem na mídia: a exposição de residências e faturas de cartão de clientes influentes geraria manchetes de primeira página.
- Cite as consequências: perda imediata da confiança dos membros, debandada de clientes para concorrentes, multas pesadas da ANPD (LGPD) e processos judiciais que poderiam levar a startup à falência.
- **Parágrafo 3 O Plano de Ação Ágil (Sem Travar o Negócio):**
- Mostre que você é parceiro(a) do crescimento e não uma barreira:
- Liste 3 ações práticas: (1) esteira automatizada que verifica falhas antes de subir novos recursos; (2) perfil exclusivo de Gerente de Concierge para a Carla atender com agilidade total; (3) proteção dos servidores e do banco de dados.
- Encerre com uma frase de confiança no futuro do Clube Aurora.

---

4. Dicas Finais para Garantir a Nota Máxima (100 pts)

1. **Evite Respostas Telegráficas de Uma Linha:** Elabore suas explicações contextualizando sempre com o cenário de luxo do Clube Aurora e a proteção de dados (LGPD).
2. **Revise a Rubrica:** Consulte a `RUBRICA.md` para confirmar que atendeu a todos os critérios de excelente.
3. **Formatação Impecável:** Se estiver usando o Word (`TEMPLATE_TG.docx`), mantenha os títulos, remova os textos de instrução entre colchetes `[...]` e confira a ortografia antes de gerar o PDF final para submissão.